

lecoo 统一登录 · 需求规格说明书 SRS（方案 O） V1.0

版本注记：O-V1.5 增量 — 手机版 + 人脸/指纹/多因子（MFA）

1. 引言

本文是方案 A SRS 的 ****SaaS / Logto 裁剪版****。FR 编号以 O- 前缀标识；原 CAS/飞书主路径 FR 标记为 Out-of-Scope。

2. 总体描述

- 角色：Visitor / Member / Admin / Owner / System
- 约束：不自研 OIDC 协议核心；不实现 CAS/SAML
- 客户端：桌面 Web + 手机 Web（响应式 / 独立手机原型）
- 安全因子：密码 / OTP / TOTP / 短信 / 邮箱 / 人脸 / 指纹 / 备用码

3. 功能需求

O-AUTH 认证

- O-AUTH-01 邮箱 OTP 登录
- O-AUTH-02 密码登录（凭证在 Logto）
- O-AUTH-03 防爆破与可配置锁定
- O-AUTH-04 OIDC Auth Code + PKCE

- O-AUTH-05 登出与管理员踢人
- O-AUTH-06 **MFA 多因子挑战** (TOTP / 短信 OTP / 邮箱 OTP / 备用恢复码)
- O-AUTH-07 **人脸识别登录 / 解锁** (WebAuthn platform / Face ID; 特征不出设备)
- O-AUTH-08 **指纹解锁** (Touch ID / BiometricPrompt / Windows Hello)
- O-AUTH-09 **生物识别注册与吊销** (需已登录 + MFA 确认)
- O-AUTH-10 **敏感操作 Step-up** (重置密钥 / 踢人 / 导出等再次挑战)
- O-AUTH-11 **手机端登录闭环** (生物优先 → 回退密码/MFA → 工作台)

O-TENANT 租户

- O-TENANT-01 创建租户
- O-TENANT-02 邀请成员 (角色 owner/admin/member)
- O-TENANT-03 接受邀请 / 邀请过期
- O-TENANT-04 禁用成员
- O-TENANT-05 租户级 MFA / 生物识别强制策略

O-APP 应用

- O-APP-01 注册应用与回调白名单
- O-APP-02 secret 一次展示与轮换
- O-APP-03 应用状态机 draft→pending→active/rejected

O-PERM 权限目录

- O-PERM-01 应用上报权限快照
- O-PERM-02 管理端只读聚合展示
- O-PERM-03 明确不参与业务实时鉴权

O-AUDIT 审计

- O-AUDIT-01 登录/成员/密钥/踢人事件
- O-AUDIT-02 MFA / 生物识别 challenge·success·fail 事件
- O-AUDIT-03 只增不改不物理删

4. 明确 Out-of-Scope（原方案 A）

- FR-CAS-* 全部
- FR-SAML-* 全部
- 飞书扫码/免登作为唯一主路径
- 外部 90 天延期引擎（企业版）
- 服务端保存原始人脸/指纹模板（禁止）

5. 接口与数据

见 `开发开工包/01-接口契约-openapi-v1.yaml` 与 `02-数据库设计-ddl-v1.sql`。

6. 验收追溯

FR	原型页面	测试
O-AUTH-01..05	登录门户	SEC-01..03,06,07
O-AUTH-06..10	⑤ 安全认证交互	SEC-MFA / BIO
O-AUTH-11	④ 手机版	移动冒烟
O-TENANT-*	C端/管理端成员	功能冒烟
O-APP-*	应用详情/管理端应用	SEC-04,08
O-PERM-*	管理端授权/目录	SEC-09
O-AUDIT-*	管理端审计	SEC-10